

CUADERNO DE CONTROL DEL RESPONSABLE

IAM (Identity Management / Identity and Access Management)

Responsable	EMP y firma de control:
Puesto previsto	Responsable de IAM (EMP-014)
VLAN de trabajo	VLAN 10 - Administración
Periodo	Inicio: Revisión: Entrega:

Meta del área

Lograr que cada EMP use únicamente las funciones de su puesto, con OneLogin y MFA, y que altas, cambios y bajas modifiquen el acceso de forma verificable.

Cómo usar este cuaderno

- ☐ Trabaje únicamente con el ID EMP; consulte el nombre en el panel privado solo cuando sea necesario.
- ☐ Revise el tablero de control al menos dos veces por semana.
- ☐ No marque una tarea como terminada sin evidencia y una prueba repetible.
- ☐ Registre bloqueos de inmediato y asígneles al área que puede resolverlos.
- ☐ Al cerrar, registre el EMP de quien entrega y el EMP de quien revisa.

Reglas comunes

No coloque contraseñas, tokens, claves, UID completos ni datos personales innecesarios en este documento, capturas, repositorios o evidencias. Use cuentas y datos de laboratorio.

1. Equipo, puestos y asignación

EMP	Puesto	Confirmación del EMP	Responsabilidad concreta	Acepta
EMP-014	Responsable de IAM		Mantiene matriz de permisos y coordina solicitudes.	[]
EMP-015	Roles y permisos / OneLogin		Configura OneLogin, grupos, roles y pruebas de autorización.	[]
EMP-016	Ciclo de vida de cuentas		Ejecuta y comprueba altas, cambios y bajas.	[]
EMP-017	MFA y autenticación		Configura segunda verificación y evidencia.	[]
EMP-018	Aprovisionamiento y documentación IAM		Documenta solicitudes, aprovisionamiento y resultados.	[]
EMP-012	Administrador de Microsoft 365		Gestiona cuentas, roles, licencias y recuperación con permisos mínimos.	[]

Acuerdo inicial del responsable

- ☐ Cada integrante entiende qué debe hacer y qué no debe hacer.
- ☐ Cada tarea tiene fecha y evidencia esperada.
- ☐ Las sustituciones de persona quedan anotadas sin cambiar el EMP del puesto.
- ☐ Las dependencias con otras áreas ya tienen contacto y fecha.

Notas de asignación

Fecha	Cambio o acuerdo	Responsable	Firma

2. Guía paso a paso

El responsable debe ejecutar estos pasos en orden. Cuando un paso dependa de otra área, registre la solicitud en la sección de dependencias.

Paso 1

Recibir el registro de RRHH y crear identidades de prueba con EMP como referencia única.

Responsable	Fecha prevista	Fecha real	Evidencia	Estado
				[]

Paso 2

Definir roles del Hub y asignar permisos mínimos: administrar, operar, consultar o sin acceso.

Responsable	Fecha prevista	Fecha real	Evidencia	Estado
				[]

Paso 3

Configurar OneLogin para la aplicación; documentar el método real y las cuentas separadas si no existe sincronización.

Responsable	Fecha prevista	Fecha real	Evidencia	Estado
				[]

Paso 4

Exigir MFA a cuentas operativas y administrativas; nunca compartir códigos o contraseñas.

Responsable	Fecha prevista	Fecha real	Evidencia	Estado
				[]

Paso 5

Probar acceso permitido y una función denegada; abrir la aplicación no equivale a administrar todo.

Responsable	Fecha prevista	Fecha real	Evidencia	Estado
				[]

Paso 6

Procesar un cambio de puesto y comprobar retiro de permisos anteriores.

Responsable	Fecha prevista	Fecha real	Evidencia	Estado
				[]

Paso 7

Procesar una baja y comprobar bloqueo de nuevo inicio y operación; revisar sesiones abiertas.

Responsable	Fecha prevista	Fecha real	Evidencia	Estado
				[]

3. Entregables y criterio de aceptación

Un entregable se considera terminado solo cuando existe, abre correctamente, coincide con el resultado real y supera el criterio indicado.

Entregable	Contenido mínimo	Criterio de aceptación	Fecha	Estado
Matriz de roles	Puesto, función, permiso y aprobador	Principio de mínimo privilegio		Pendiente / Revisión / Aprobado
Configuración OneLogin	Aplicación, grupos, roles y MFA	Sin secretos en capturas		Pendiente / Revisión / Aprobado
Prueba positiva	Usuario autorizado ejecuta función	Evento registrado		Pendiente / Revisión / Aprobado
Prueba negativa	Usuario sin rol recibe rechazo	Sin fuga de datos		Pendiente / Revisión / Aprobado
Ciclo de vida	Alta, cambio y baja	Resultados y tiempos documentados		Pendiente / Revisión / Aprobado

Control de archivos

Archivo o enlace	Versión	Dueño	Revisó	Resultado

4. Plan de trabajo y control de personas

Copie una fila por tarea. Use: P = pendiente, C = en curso, B = bloqueada, T = terminada. Una tarea T debe tener evidencia.

EMP / persona	Tarea	Entrega esperada	Fecha	Estado	Evidencia / bloqueo

Indicadores del área

Indicador	Meta	Actual	Acción
Tareas terminadas	100 % antes del ensayo		
Entregables aceptados	5 de 5		
Bloqueos sin dueño	0		
Pruebas aprobadas	5 de 5		

5. Pruebas que debe dirigir el responsable

Ejecute cada prueba con la persona asignada. Escriba el resultado observado; no use 'funciona' sin indicar qué ocurrió.

Prueba	Ejecutor	Fecha/hora	Resultado obtenido	Evidencia	Estado
OneLogin solicita MFA.					A / F / P
Cada EMP tiene rol esperado.					A / F / P
El rechazo es real y queda registrado.					A / F / P
Una baja impide la siguiente operación.					A / F / P
TI puede cambiar permisos desde interfaz auditada.					A / F / P

Cómo documentar una prueba

- ☐ Anote fecha, hora, equipo, cuenta de prueba y ejecutor.
- ☐ Capture el estado inicial, la acción y el resultado final.
- ☐ Incluya una prueba que debe fallar, no solo casos permitidos.
- ☐ Oculte contraseñas, tokens, correos personales y UID completos.
- ☐ Si falla, abra una acción correctiva, repita y conserve ambos resultados.

Leyenda: A = aprobada; F = fallida; P = pendiente.

6. Dependencias, bloqueos y coordinación

RRHH origina solicitudes; responsables aprueban; TI mantiene Hub; SOC consulta eventos; Auditoría verifica.

Fecha	Necesidad o bloqueo	Área/persona solicitada	Fecha compromiso	Resultado

Reunión de seguimiento

Fecha	Avance desde la reunión anterior	Siguiente acción	Dueño y fecha

7. Cierre y entrega del área

- ☐ Todos los integrantes entregaron su parte o existe sustitución documentada.
- ☐ Los entregables cumplen sus criterios y pueden abrirse desde otro equipo.
- ☐ Las pruebas tienen resultado real y evidencia asociada.
- ☐ Las configuraciones se pueden repetir con la guía.
- ☐ Los repositorios y capturas no contienen secretos ni datos personales innecesarios.
- ☐ Las limitaciones y adaptaciones están escritas y fueron comunicadas.
- ☐ Auditoría recibió el índice final de evidencias.
- ☐ Dirección recibió el resumen y el guion de demostración.

Resumen para Dirección y Auditoría

Logro principal	
Pendiente o limitación	
Prueba más importante	
Ruta de evidencias	
Duración de demostración	

Responsable del área	Revisor / área receptora
EMP: Firma: Fecha:	EMP: Firma: Fecha: